



Seguridad

Seguridad en SI

Estar protegidos ante problemas:

- Accidentales. Pérdida información.
- Intencionales. Privacidad. Control de Acceso. Pérdida de información.

Conceptos:

- Seguridad: Protección contra pérdida de datos. Accidental o intencional.
- Integridad: Protección contra la pérdida de consistencia. Accidental.

Niveles de Seguridad

(el orden es importante)

- Humano. Políticas de gestión de los RRHH.
- Físico. Políticas de acceso al HW.
- SO.
- DB -> Nosotros nos enfocamos en este.

Cada nivel se apoya sobre el anterior.

La seguridad a nivel de DB básicamente se refiere a autorizar o desautorizar acciones de los usuarios sobre los objetos de la base de datos.

Algunos conceptos muy importantes

- Privilegio -> Permiso para hacer algo
- Usuario -> Alguien / Algo
- Grupo -> Conjunto de Usuarios
- Perfil -> Conjunto de Permisos

Un usuario/grupo/perfil puede recibir permisos de tres formas:

- Explícitamente.
- Heredado.
- Un usuario tiene todos los privilegios sobre los objetos que el mismo crea.

Algunos motores tienen un rol genérico (public por ejemplo en Postgres) al que están asociados todos los usuarios de manera que aquellos objetos que asignan permisos a ese rol, es como si se lo estuvieran asignando a TODOS o cualquier usuario.

Delegación de privilegios

Los usuarios pueden otorgar privilegios o otros usuarios o roles sobre los objetos que el primero crea o es propietario.

También pueden otorgar privilegios cuando recibieron los mismos con la cláusula “with grant option”.

Los privilegios están clasificados en:

- Privilegios de objeto.
- Privilegios de sistema.

Como se organizan los privilegios y cuales existen depende de los distintos motores.

Privilegios de objeto

- Sobre una tabla:
 - Select.
 - Insert
 - Delete
 - Update
 - Truncate
 - Reference.
 - Trigger.

Privilegios de objeto

- Sobre una función:
 - Execute.

Privilegios de objeto

- Sobre una vista:
 - Select.
 - Insert.
 - Update.
 - Delete.

Privilegios de objeto

- Sobre una DB:
 - Connect.
 - All.

Privilegios de objeto

- Sobre un esquema:
 - Usage.
 - All.

Privilegios de sistema

- Administración. Superuser.
- Create Role.
- Create Database.
- Replication.
- Login.

Vistas como mecanismo de seguridad

- Permite a un usuario que acceda a una parte de la información almacenada en una relación.

Sintaxis para la creación de un rol.

```
CREATE ROLE tutifruti_adm WITH  
    NOLOGIN  
    NOSUPERUSER  
    INHERIT  
    NOCREATEDB  
    NOCREATEROLE  
    NOREPLICATION;
```

Sintaxis para la creación de un usuario.

```
CREATE USER tutifruti_pdi WITH  
  LOGIN  
  NOSUPERUSER  
  INHERIT  
  NOCREATEDB  
  CREATEROLE  
  NOREPLICATION  
  ENCRYPTED PASSWORD 'md517fbb29745e3029df4bf63e65f36e2bb';
```

Sintaxis para la asignación de privilegios

- De objeto.

GRANT ALL ON TABLE main.pais TO tutifruti_adm;

GRANT INSERT, SELECT, UPDATE, DELETE ON TABLE main.pais TO tutifruti_app;

GRANT SELECT ON TABLE main.pais TO tutifruti_select;

GRANT CONNECT ON DATABASE tutifruti TO tutifruti_adm;

GRANT USAGE ON SCHEMA main TO tutifruti_select;

- De sistema.

ALTER ROLE dbafp SUPERUSER;

Sintaxis para la eliminación de privilegios

- De objeto.

```
REVOKE ALL ON TABLE main.pais FROM tutifruti_adm;
```

```
REVOKE INSERT, SELECT, UPDATE, DELETE ON TABLE main.pais FROM  
tutifruti_app;
```

```
REVOKE SELECT ON TABLE main.pais FROM tutifruti_select;
```

- De sistema.

```
ALTER ROLE dbafp NOSUPERUSER;
```

Sintaxis para la asignación de un rol a un usuario

```
GRANT tutifruti_select TO tutifruti_pdi;
```

Sintaxis para el eliminación de un rol a un usuario

```
REVOKE tutifruti_select FROM tutifruti_pdi;
```


Organización de privilegios en categorías funcionales

- Organización frecuente:
 - Administración.
 - Consulta.
 - Aplicación.
- Cada motor ofrece un conjunto de permisos y técnicas como herramientas para implementar la seguridad de los datos.
- En general no son complejas y el verdadero desafío es la definición de las políticas de seguridad que mejor se adapten a la organización en la que se van a implementar.
- Hay que tomar una decisión de compromiso que articule:
 - Flujos de trabajo de la organización.
 - Funcionalidades ofrecidas por las herramientas disponibles.
 - Posibilidad de adaptación de las prácticas llevadas adelante por los participantes.
 - Factibilidad de mantenimiento de las políticas de seguridad.